AuthGuard Security Assessment Report

Target: http://127.0.0.1:8001 | **Status:** COMPLETED

Metric	Value
Assessment Name	Quarterly Website Authentication Resilience Audit
Target Host	127.0.0.1
Total Tests Run	9
Passed Checks	0
Findings Identified	9
Requests Budget / Used	21 / 200

Security Findings & Weaknesses

OTP Verification Bypass on Invalid Code (Critical - CVSS 9.1)

Endpoint: /verify-otp
Description: The server accepted an obviously invalid OTP code ('000000') or returned 200 OK without verification.

Remediation: *Enforce strict cryptographic comparison of OTP secrets and reject unverified codes.*

OTP Replay / Reuse Vulnerability (Critical - CVSS 9.1)

Endpoint: /verify-otp
Description: The server permitted reuse of an already submitted One-Time Password.

Remediation: *Mark OTP tokens as consumed in the database immediately upon successful verification.*

Missing OTP Attempt Rate Limiting (Medium - CVSS 5.3)

Endpoint: /verify-otp
Description: Endpoint permitted 5 consecutive invalid OTP attempts without rate-limiting (HTTP 429) or lockout.

Remediation: *Enforce strict per-account and per-IP attempt limits (max 3-5 failed tries per OTP).*

Unbound OTP Verification State (High - CVSS 7.5)

Endpoint: /verify-otp
Description: Server accepted OTP verification without user account or session binding.

Remediation: *Bind OTP secrets strictly to the server-side session of the authenticating user.*

Missing Rate Limiting on Authentication Endpoint (Medium - CVSS 5.3)

Endpoint: /login
Description: Authentication endpoint '/login' processed repeated invalid logins without returning HTTP 429 (Too Many Requests), rate-limit headers, or progressive backoff.

Remediation: *Implement IP and username based rate limiting (e.g., token bucket or leaky bucket algorithm) returning HTTP 429.*

Authentication Account Enumeration Weakness (Low - CVSS 3.7)

Endpoint: /login
Description: The authentication endpoint returns distinguishable error messages or status codes for valid usernames versus invalid usernames, allowing adversaries to enumerate valid accounts.

Remediation: *Normalize all authentication failure messages and response times to be indistinguishable.*

Missing Server-Side CAPTCHA Enforcement (Medium - CVSS 6.5)

Endpoint: /login
Description: Authentication endpoint '/login' accepted an authentication request without requiring a CAPTCHA response token.

Remediation: *Enforce mandatory server-side verification of CAPTCHA tokens with the provider before processing credentials.*

Forged CAPTCHA Token Accepted (High - CVSS 7.5)

Endpoint: /login
Description: Server accepted a fabricated CAPTCHA token without validating its signature with the CAPTCHA verification API.

Remediation: *Validate every token server-side via the provider secret key and verify success: true.*

CAPTCHA Token Replay / Reuse Vulnerability (Medium - CVSS 5.8)

Endpoint: /login
Description: The server permitted reuse of an already submitted CAPTCHA token across multiple requests.

Remediation: *Ensure CAPTCHA tokens are consumed or enforce provider timestamp and hostname validation.*